

OpenCode Project

API Specification

Spring Boot 3.2.5 / Java 21 / Maven

Generated from codebase analysis

Base URL: <http://localhost:8080>

Total Endpoints: **48** (7 public + 41 authenticated)

Table of Contents

1. Overview
2. Technology Stack
3. Authentication
4. Authentication Endpoints
5. Expense Endpoints
6. User Management Endpoints
7. Tenant Management Endpoints
8. Role Management Endpoints
9. Department Management Endpoints
10. Audit Log Endpoints
11. Data Models
12. Error Handling
13. Permissions Reference
14. Roles Reference

1. Overview

This document describes all REST API endpoints exposed by the Spring Boot Boilerplate application. The system implements a multi-tenant expense management platform with role-based access control (RBAC), JWT authentication, multi-factor authentication (MFA), audit logging, and rate limiting.

Architecture: Controller → Service → Repository → Database

Response Format: All endpoints return `ApiResponse<T>` with fields: `success` (boolean), `message` (String), `data` (T), `timestamp` (ISO-8601).

2. Technology Stack

Component	Technology	Version
Language	Java	21
Framework	Spring Boot	3.2.5
Build	Maven	Wrapper
ORM	Spring Data JPA + Hibernate	Via Spring Boot
Migrations	Flyway	16 versions
Auth	Spring Security + JJWT	0.12.5
Password	BCrypt	Strength 12
MFA	TOTP / Email	1.7.1
Cache	Redis	Via Spring Boot
Validation	Jakarta Bean Validation	Via Spring Boot
Dev DB	H2 (in-memory)	-
Prod DB	PostgreSQL	-

3. Authentication

The API uses **JWT-based stateless authentication**. Clients authenticate via `POST /api/auth/login` and receive an access token. The access token must be sent in the `Authorization: Bearer <token>` header.

3.1 JWT Configuration

Property	Value
Algorithm	HMAC-SHA512
Access Token Expiry	900,000 ms (15 minutes)
Refresh Token Expiry	604,800,000 ms (7 days)
Issuer	security-boilerplate
Audience	api.security-boilerplate
Password Encoding	BCrypt (strength 12)
Session Policy	STATELESS

3.2 Access Token Claims

Claim	Type	Description
sub	String	Username
roles	List<String>	Authorities (ROLE_*, EXPENSE_READ, etc.)
userId	Long	User database ID
tenantId	Long	Tenant ID (null for super admin)
departmentId	Long	Department ID
jti	UUID	Unique token ID for blacklisting

3.3 Authentication Flow

1. Login: Client sends credentials to `POST /api/auth/login`. If MFA is enabled, returns `MfaLoginResponse` with a temporary session token. Otherwise returns `TokenResponse` with access and refresh tokens. Refresh token is set in an `httpOnly`, `secure`, `SameSite=Strict` cookie.

2. MFA Verification: If MFA is required, client sends the session token and 6-digit code to `POST /api/auth/mfa/verify`. On success, returns the full token pair.

3. Token Refresh: Client sends `POST /api/auth/refresh` (refresh token read from cookie). Issues new access+refresh pair (rotation). Old refresh token is revoked.

4. Logout: Client sends POST /api/auth/logout. Blacklists the access token JTI in Redis. Revokes refresh tokens. Clears the refresh token cookie.

3.4 Security Features

Account Lockout: 5 failed attempts → 15 min lockout. **Rate Limiting:** Redis-based sliding window (forgot-password: 10/min, reset-password: 10/min, MFA verify: 10/min). **Password Reset Tokens:** SHA-256 hashed, single-use, time-limited. **Refresh Tokens:** Stored in Redis, SHA-256 hashed, rotated on use.

4. Authentication Endpoints

Base Path: /api/auth

Method	Path	Description	Auth
POST	/api/auth/login	Login with credentials	Public
POST	/api/auth/mfa/verify	Verify MFA code	Public
POST	/api/auth/refresh	Refresh access token (cookie)	Public
POST	/api/auth/forgot-password	Request password reset email	Public
POST	/api/auth/reset-password	Reset password with token	Public
POST	/api/auth/logout	Logout, revoke tokens	Authenticated
GET	/api/auth/me	Get current user profile	Authenticated
POST	/api/auth/change-password	Change password	Authenticated

LoginRequest

Field	Type	Validation	Description
usernameOrEmail	String	@NotBlank	Username or email address
password	String	@NotBlank, @Size(max=100)	Password
rememberMe	Boolean	-	Optional remember-me flag

TokenResponse

Field	Type	Validation	Description
accessToken	String	-	JWT access token
refreshToken	String	-	JWT refresh token (stripped in response)
tokenType	String	-	Always 'Bearer'
expiresIn	long	-	Access token expiry (ms)
username	String	-	Authenticated username
roles	String[]	-	Granted authorities

MfaLoginResponse

Field	Type	Validation	Description
mfaRequired	boolean	-	Always true
mfaSessionToken	String	-	Temporary token for MFA verification
method	String	-	MFA method (TOTP, EMAIL)
expiresIn	long	-	Session token expiry (ms)

MfaVerifyRequest

Field	Type	Validation	Description
mfaSessionToken	String	@NotBlank	MFA session token from login
code	String	@NotBlank, @Size(min=6, max=6)	6-digit MFA code

ChangePasswordRequest

Field	Type	Validation	Description
currentPassword	String	@NotBlank	Current password
newPassword	String	@NotBlank, @Password	New password (custom validation)
confirmPassword	String	@NotBlank	Confirmation of new password

ForgotPasswordRequest

Field	Type	Validation	Description
email	String	@NotBlank, @Email	Email address for reset link

ResetPasswordRequest

Field	Type	Validation	Description
token	String	@NotBlank	Password reset token
newPassword	String	@NotBlank, @Password	New password
confirmPassword	String	@NotBlank	Confirmation of new password

UserProfileResponse

Field	Type	Validation	Description
username	String	-	Username
email	String	-	Email address
firstName	String	-	First name
lastName	String	-	Last name
roles	String[]	-	Assigned role names
enabled	Boolean	-	Whether account is enabled
mfaEnabled	Boolean	-	Whether MFA is enabled
mfaMethod	String	-	MFA method if enabled

5. Expense Endpoints

Base Path: /api/expenses

Method	Path	Description	Auth
GET	/api/expenses	List expenses (paginated, filtered)	EXPENSE_READ
GET	/api/expenses/{id}	Get expense by ID	EXPENSE_READ
POST	/api/expenses	Create expense	EXPENSE_CREATE
PUT	/api/expenses/{id}	Update expense	EXPENSE_UPDATE
POST	/api/expenses/{id}/cancel	Cancel expense	EXPENSE_UPDATE
POST	/api/expenses/{id}/approve	Approve expense	EXPENSE_APPROVE
POST	/api/expenses/{id}/reject	Reject expense	EXPENSE_REJECT
POST	/api/expenses/{id}/process	Process for payment	EXPENSE_PROCESS

Query Parameters (GET /api/expenses):

Parameter	Type	Description
status	ExpenseStatus	Filter by status (PENDING, APPROVED, REJECTED, CANCELLED, PROCESSED)
tenantId	Long	Filter by tenant ID
departmentId	Long	Filter by department ID
page	Integer	Page number (default 0)
size	Integer	Page size (default 20)
sort	String	Sort field and direction (e.g., submissionDate,desc)

ExpenseCreateRequest

Field	Type	Validation	Description
title	String	@NotBlank, @Size(max=200)	Expense title
description	String	@Size(max=1000)	Optional description
amount	BigDecimal	@NotNull, @Positive, @Digits(12,4)	Expense amount
category	String	@NotBlank, @Size(max=50)	Expense category
departmentId	Long	-	Optional department association

ExpenseUpdateRequest

Field	Type	Validation	Description
title	String	@NotBlank, @Size(max=200)	Expense title
description	String	@Size(max=1000)	Optional description
amount	BigDecimal	@NotNull, @Positive, @Digits(12,4)	Expense amount
category	String	@NotBlank, @Size(max=50)	Expense category

ExpenseResponse

Field	Type	Validation	Description
id	Long	-	Expense ID
title	String	-	Title
description	String	-	Description
amount	BigDecimal	-	Amount
category	String	-	Category
status	ExpenseStatus	-	PENDING, APPROVED, REJECTED, CANCELLED, PROCESSED
submissionDate	Instant	-	When submitted
decisionDate	Instant	-	When approved/rejectedd
processedDate	Instant	-	When processed for payment
ownerId	Long	-	Owner user ID
ownerUsername	String	-	Owner username
departmentId	Long	-	Department ID
departmentName	String	-	Department name
tenantId	Long	-	Tenant ID
tenantName	String	-	Tenant name
approvedById	Long	-	Approver user ID
approvedByUsername	String	-	Approver username
rejectedById	Long	-	Rejector user ID
rejectedByUsername	String	-	Rejector username
processedById	Long	-	Processor user ID
processedByUsername	String	-	Processor username
updatedAt	Instant	-	Last update timestamp

6. User Management Endpoints

Base Path: /api/management/users

Method	Path	Description	Auth
POST	/api/management/users	Create user	USER_CREATE
GET	/api/management/users	List users (paginated)	USER_READ
GET	/api/management/users/{id}	Get user by ID	USER_READ
PUT	/api/management/users/{id}	Update user	USER_WRITE
DELETE	/api/management/users/{id}	Delete user	USER_DELETE
POST	/api/management/users/{id}/enable	Toggle enabled state	USER_ENABLE
POST	/api/management/users/{id}/roles	Assign role to user	USER_ASSIGN_ROLE
DELETE	/api/management/users/{id}/roles	Remove role from user	USER_ASSIGN_ROLE
POST	/api/management/users/{id}/mfa/enable	Enable MFA for user	USER_WRITE
POST	/api/management/users/{id}/mfa/disable	Disable MFA for user	USER_WRITE
POST	/api/management/users/{id}/mfa/reset	Reset MFA for user	USER_WRITE

UserCreateRequest

Field	Type	Validation	Description
username	String	@NotBlank, @Size(min=3, max=50)	Username
email	String	@NotBlank, @Email, @Size(max=100)	Email
password	String	@NotBlank, @Password	Password (custom validation)
firstName	String	@Size(max=50)	First name
lastName	String	@Size(max=50)	Last name
roleName	String	@Size(max=50)	Optional role name to assign
tenantId	Long	-	Optional tenant ID
departmentId	Long	@NotNull	Required department ID

UserUpdateRequest

Field	Type	Validation	Description
firstName	String	@Size(max=50)	First name
lastName	String	@Size(max=50)	Last name
departmentId	Long	-	Optional department ID

UserResponse

Field	Type	Validation	Description
id	Long	-	User ID
username	String	-	Username
email	String	-	Email
firstName	String	-	First name
lastName	String	-	Last name
enabled	Boolean	-	Account enabled
accountNonLocked	Boolean	-	Account locked status
departmentId	Long	-	Department ID
departmentName	String	-	Department name
roles	Set<String>	-	Assigned role names
permissions	Set<String>	-	All effective permissions
mfaEnabled	Boolean	-	MFA enabled
mfaMethod	String	-	MFA method
createdAt	Instant	-	Creation timestamp
updatedAt	Instant	-	Last update timestamp

UserEnableRequest

Field	Type	Validation	Description
enabled	Boolean	@NotNull	Desired enabled state

UserRoleAssignmentRequest

Field	Type	Validation	Description
roleName	String	@NotBlank	Role name to assign/remove

UserMfaToggleRequest

Field	Type	Validation	Description
method	MfaMethod	@NotNull	MFA method (TOTP or EMAIL)

7. Tenant Management Endpoints

Base Path: /api/management/tenants

Method	Path	Description	Auth
GET	/api/management/tenants	List tenants (paginated, filtered)	TENANT_READ
GET	/api/management/tenants/{id}	Get tenant by ID	TENANT_READ
POST	/api/management/tenants	Create tenant	TENANT_CREATE
PUT	/api/management/tenants/{id}	Update tenant	TENANT_UPDATE
DELETE	/api/management/tenants/{id}	Delete tenant	TENANT_DELETE

TenantCreateRequest

Field	Type	Validation	Description
name	String	@NotBlank, @Size(max=100)	Tenant name
status	TenantStatus	@NotNull	ACTIVE, INACTIVE, SUSPENDED

TenantUpdateRequest

Field	Type	Validation	Description
name	String	@NotBlank, @Size(max=100)	Tenant name
status	TenantStatus	@NotNull	ACTIVE, INACTIVE, SUSPENDED

TenantResponse

Field	Type	Validation	Description
id	Long	-	Tenant ID
name	String	-	Tenant name
status	TenantStatus	-	ACTIVE, INACTIVE, SUSPENDED
createdAt	Instant	-	Creation timestamp

8. Role Management Endpoints

Base Path: /api/management/roles

Method	Path	Description	Auth
--------	------	-------------	------

GET	/api/management/roles	List roles (paginated)	ROLE_READ
GET	/api/management/roles/{id}	Get role by ID	ROLE_READ
POST	/api/management/roles	Create role	hasRole(PLATFORM_ADMIN)
PUT	/api/management/roles/{id}	Update role	hasRole(PLATFORM_ADMIN)
DELETE	/api/management/roles/{id}	Delete role	hasRole(PLATFORM_ADMIN)
POST	/api/management/roles/{id}/permissions	Add permission	hasRole(PLATFORM_ADMIN)
DELETE	/api/management/roles/{id}/permissions	Remove permission	hasRole(PLATFORM_ADMIN)

RoleCreateRequest

Field	Type	Validation	Description
name	String	@NotBlank, @Size(max=50)	Role name (unique key)
title	String	@Size(max=100)	Human-readable title
description	String	@Size(max=255)	Description

RolePermissionRequest

Field	Type	Validation	Description
permission	UserPermission	@NotNull	Permission enum value

RoleResponse

Field	Type	Validation	Description
id	Long	-	Role ID
name	String	-	Role name
title	String	-	Human-readable title
description	String	-	Description
permissions	Set<UserPermission>	-	Assigned permissions

9. Department Management Endpoints

Base Path: /api/management/departments

Method	Path	Description	Auth
GET	/api/management/departments	List departments (paginated)	DEPARTMENT_READ
GET	/api/management/departments/{id}	Get department by ID	DEPARTMENT_READ
POST	/api/management/departments	Create department	DEPARTMENT_CREATE
PUT	/api/management/departments/{id}	Update department	DEPARTMENT_UPDATE
DELETE	/api/management/departments/{id}	Delete department	DEPARTMENT_DELETE

DepartmentCreateRequest

Field	Type	Validation	Description
name	String	@NotBlank, @Size(max=100)	Department name
tenantId	Long	@NotNull	Parent tenant ID
managerIds	List<Long>	-	Optional list of manager user IDs

DepartmentUpdateRequest

Field	Type	Validation	Description
name	String	@NotBlank, @Size(max=100)	Department name
managerIds	List<Long>	-	Optional list of manager user IDs

DepartmentResponse

Field	Type	Validation	Description
id	Long	-	Department ID
name	String	-	Department name
tenantId	Long	-	Parent tenant ID
tenantName	String	-	Parent tenant name
managerIds	List<Long>	-	Manager user IDs
managerUsernames	List<String>	-	Manager usernames

10. Audit Log Endpoints

Base Path: /api/management/audit

Method	Path	Description	Auth
GET	/api/management/audit	List audit logs (paginated)	AUDIT_LOG_READ
GET	/api/management/audit/{id}	Get audit log by ID	AUDIT_LOG_READ

AuditLogResponse

Field	Type	Validation	Description
id	Long	-	Audit log ID
actorId	Long	-	Actor user ID
actorUsername	String	-	Actor username
tenantId	Long	-	Tenant ID
action	String	-	Action performed
resourceType	String	-	Resource type (USER, EXPENSE, TENANT)
resourceId	String	-	Resource ID
details	String	-	Additional details
timestamp	Instant	-	When the action occurred

11. Data Models

11.1 ExpenseStatus Enum

Value	Description
PENDING	Expense submitted, awaiting review
APPROVED	Expense approved by a manager
REJECTED	Expense rejected by a manager
CANCELLED	Expense cancelled by the owner
PROCESSED	Approved expense processed for payment

11.2 TenantStatus Enum

Value	Description
ACTIVE	Tenant is active and operational
INACTIVE	Tenant is temporarily inactive
SUSPENDED	Tenant is suspended

11.3 MfaMethod Enum

Value	Description
NONE	No MFA configured
TOTP	Time-based One-Time Password (authenticator app)
EMAIL	Email-based MFA codes

11.4 Entity Relationships

Tenant 1----<M Department
Tenant 1----<M User
Tenant 1----<M Expense
Department M>---M User (via department_managers)
Department 1----<M Expense
User M>---M Role (via user_roles)
Role 1----<M UserPermission (via role_permissions)
User 1----<M Expense (as owner)
User 1----<M RefreshToken
User 1----<M PasswordResetToken

11.5 Database Tables

Table	Description	Key Indexes
users	User accounts with auth details	unique: username, email
roles	Role definitions	unique: name
user_roles	User-role junction table	user_id, role_id
role_permissions	Role permissions (@ElementCollection)	role_id
tenants	Multi-tenant organizations	unique: name
departments	Departments within tenants	unique: (tenant_id, name)
department_managers	Department-manager junction	department_id, user_id
expenses	Expense records	tenant, department, owner, status
audit_logs	Audit trail entries	tenant, actor, resource, timestamp
refresh_tokens	Refresh tokens (Redis-backed)	unique: token_hash
password_reset_tokens	Password reset tokens	unique: token_hash

12. Error Handling

All exceptions are caught by `GlobalExceptionHandler` and returned as `ApiResponse` with appropriate HTTP status codes.

Exception	HTTP Status	Response Message
<code>MethodArgumentNotValidException</code>	400 Bad Request	Validation failed
<code>ConstraintViolationException</code>	400 Bad Request	Validation failed
<code>BadCredentialsException</code>	401 Unauthorized	Invalid credentials
<code>UsernameNotFoundException</code>	401 Unauthorized	Invalid credentials
<code>LockedException</code>	429 Too Many Requests	(lockout message)
<code>AccessDeniedException</code>	403 Forbidden	Access denied: Insufficient permissions
<code>IllegalArgumentException</code>	400 Bad Request	(contextual message)
<code>IllegalStateException</code>	409 Conflict	(contextual message)
<code>DataIntegrityViolationException</code>	400 Bad Request	A record with the same value already exists
Exception (catch-all)	500 Internal Server Error	An unexpected error occurred

13. Permissions Reference

All permissions are defined in the `UserPermission` enum and used in `@PreAuthorize` annotations via `hasAuthority()`.

Category	Permissions
Tenant Management	TENANT_READ, TENANT_CREATE, TENANT_UPDATE, TENANT_DELETE
User Management	USER_READ, USER_WRITE, USER_CREATE, USER_UPDATE, USER_DELETE, USER_ENABLE, USER_ASSIGN_ROLE
Role Management	ROLE_READ, ROLE_WRITE, ROLE_DELETE, ROLE_ASSIGN_PERMISSION
Department Management	DEPARTMENT_READ, DEPARTMENT_CREATE, DEPARTMENT_UPDATE, DEPARTMENT_DELETE
Expense Management	EXPENSE_READ, EXPENSE_READ_ALL, EXPENSE_CREATE, EXPENSE_UPDATE, EXPENSE_DELETE, EXPENSE_APPROVE, EXPENSE_REJECT, EXPENSE_PROCESS
MFA Management	MFA_MANAGE

14. Roles Reference

Roles are seeded in Flyway migrations. Each role grants a specific set of permissions.

Role	Description	Key Permissions
PLATFORM_ADMIN	Super admin (no tenant)	All permissions
TENANT_ADMIN	Tenant administrator	All except TENANT_CREATE, TENANT_DELETE
USER_MANAGER	Manages users	USER_READ, USER_WRITE, USER_CREATE, USER_ASSIGN_ROLE
DEPARTMENT_MANAGER	Department manager	USER_READ, DEPARTMENT_READ, EXPENSE_READ, EXPENSE_APPROVE, EXPENSE_REJECT, REPORT_READ
EMPLOYEE	Regular employee	EXPENSE_READ, EXPENSE_CREATE, EXPENSE_UPDATE, EXPENSE_DELETE
AUDITOR	Read-only auditor	USER_READ, DEPARTMENT_READ, EXPENSE_READ, REPORT_READ, AUDIT_LOG_READ, EXPENSE_READ_ALL
FINANCE	Finance processor	EXPENSE_READ, EXPENSE_PROCESS, REPORT_READ, EXPENSE_READ_ALL